

5. Plan de mejora continua

Acciones posteriores a la entrega, vinculadas con limitaciones observables del prototipo y definidas mediante indicadores verificables.

10 acciones concretas	6 prioridad alta	4 prioridad media	1 propuesta de innovación
--------------------------	---------------------	----------------------	------------------------------

Contexto y propósito

ModuShield cumple actualmente con el flujo principal de un gateway de seguridad: autenticación JWT, autorización por roles, API key heredada, restricción de rutas y métodos, límites de tamaño y tasa, auditoría, manejo de errores, pruebas unitarias con cobertura mínima y despliegue de prueba automatizado con Docker Compose. El siguiente plan propone acciones posteriores a la entrega que responden a limitaciones observables del prototipo. Cada acción tiene un resultado verificable para evitar propuestas generales o imposibles de evaluar.

Acciones propuestas

Mejora propuesta	Acción concreta	Indicador de éxito	Prioridad	Horizonte
Endurecer los JWT	Reducir los access tokens a 15 minutos e implementar refresh tokens de un solo uso, rotación y revocación al cerrar sesión.	Ningún access token supera 15 minutos; reutilizar un refresh token devuelve 401; pruebas automatizadas cubren emisión, rotación, expiración y revocación.	Alta	1-2 sprints
Reemplazar la API key compartida	Crear credenciales distintas por cliente para /api/orders, con 256 bits aleatorios, identificador público, hash del secreto, fecha de expiración y revocación. Rechazar placeholders y claves menores a 32 bytes al iniciar.	100% de claves cumplen el mínimo; una clave revocada deja de funcionar en menos de 60 segundos; ningún secreto completo aparece en almacenamiento o logs.	Alta	1-2 sprints
Incorporar persistencia	Migrar usuarios, productos, refresh tokens y metadatos de clientes a PostgreSQL con Flyway.	Los datos sobreviven al reinicio; migraciones se ejecutan desde una base vacía; pruebas de integración validan registro, login y CRUD persistente.	Alta	2-3 sprints
Automatizar seguridad dinámica	Añadir un job de OWASP ZAP autenticado contra el Compose efímero, con contextos USER y ADMIN y exportación HTML como artefacto.	Cada PR ejecuta el baseline; main ejecuta escaneo autenticado; cero alertas High no justificadas y 100% de reportes quedan como artefactos.	Alta	1 sprint
Fortalecer calidad estática	Integrar SonarQube o SonarCloud con los XML de JaCoCo y bloquear merges por Quality Gate. Corregir todos los hallazgos Blocker y Critical.	Quality Gate aprobado; 0 vulnerabilidades Blocker o Critical; cobertura >=80% por módulo y duplicación <5%.	Alta	1 sprint

Mejora propuesta	Acción concreta	Indicador de éxito	Prioridad	Horizonte
Proteger transporte y secretos	Terminar TLS en un reverse proxy para ambientes no locales y cargar secretos desde un gestor en lugar de .env. Documentar la rotación.	100% del tráfico externo usa HTTPS; el escaneo no acepta TLS obsoleto; ningún secreto de despliegue reside en archivos o variables permanentes del repositorio.	Alta	2 sprints
Escalar el rate limit	Sustituir buckets locales por Redis y probar dos instancias del gateway compartiendo la misma cuota.	La sexta solicitud global recibe 429 aunque las cinco anteriores se distribuyan entre dos instancias; prueba de concurrencia determinista aprobada.	Media	2 sprints
Observabilidad operativa	Exponer métricas Prometheus de latencia, 401, 403, 429, 5xx y upstream; crear un dashboard y alertas.	Dashboard con p50, p95 y p99; alerta si 5xx supera 2% durante 5 minutos; métricas y logs comparten request ID.	Media	1-2 sprints
Cadena de suministro	Generar un SBOM CycloneDX y ejecutar análisis de dependencias e imágenes en CI.	SBOM por build; cero CVE Critical no aceptadas; una CVE High requiere corrección o excepción documentada antes del merge.	Media	1 sprint
Innovación: defensa adaptativa basada en riesgo	Construir un prototipo que calcule un puntaje de riesgo por cliente usando tasa de 401 y 403, rutas inexistentes, variación de IP y ráfagas. Aplicar temporalmente límites más estrictos solo a identidades de alto riesgo, conservando las reglas deterministas actuales como fallback.	Con un conjunto sintético versionado de tráfico normal y ataques, detectar >=90% de patrones maliciosos con <=5% de falsos positivos; decisión explicable en auditoría y desactivable por configuración.	Media	3 sprints

Estado actual y ampliación prevista de OWASP ZAP

Evidencia completada	Resultado observado	Mejora futura
OWASP ZAP 2.17.0 se ejecutó como analizador pasivo sobre GET /health en el entorno Docker local. Se conservaron los reportes inicial y final.	El análisis inicial registró 1 alerta Low, confianza media, por ausencia de X-Content-Type-Options. Tras agregar nosniff, el análisis final registró 0 alertas dentro de ese alcance.	Ampliar el contexto a rutas USER y ADMIN, ejecutar pruebas activas solo en un entorno autorizado y automatizar un baseline en CI. Éxito: reporte por ejecución y cero alertas High no justificadas.

Justificación de la innovación

La innovación propuesta está relacionada directamente con la función de ModuShield. Un límite fijo de cinco solicitudes protege la demostración, pero trata igual a un cliente legítimo y a uno que acumula tokens inválidos, rutas prohibidas o ráfagas anómalas. El puntaje de riesgo permitiría responder de forma gradual sin sustituir las políticas existentes.

El prototipo no debe entrenarse con datos personales ni tomar decisiones opacas: utilizará señales técnicas minimizadas, datos sintéticos versionados y registrará qué factores produjeron cada decisión.

Seguimiento y evidencia

Elemento	Evidencia esperada al cierre de cada sprint
1. Responsabilidad	Issue o historia con responsable y fecha objetivo.
2. Implementación	Pull request con revisión y pruebas automatizadas.
3. Medición	Métrica antes y después de la mejora.
4. Verificación	Evidencia de CI o reporte emitido por la herramienta correspondiente.
5. Decisión	Estado completado, ajustado o pospuesto, acompañado de una justificación.

Las prioridades altas atienden riesgos presentes del prototipo: credenciales compartidas, persistencia, análisis de seguridad y manejo de secretos. La innovación se ejecutará después de estabilizar esas bases para no introducir complejidad sobre controles incompletos.

Actualización prevista del análisis SonarQube

Evidencia disponible	Acción futura	Indicador de éxito
El equipo sí ejecutó SonarQube y conserva el reporte como evidencia. Ese análisis corresponde a una versión anterior a las últimas incorporaciones de JWT, pruebas JUnit 5 y JaCoCo, y automatización CI/CD; por ello se identifica como evidencia histórica y no como análisis del commit final.	Repetir SonarQube sobre la versión final actualizada, publicar el commit exacto analizado e integrar los XML de JaCoCo. El nuevo resultado complementará o sustituirá el reporte histórico en una entrega posterior.	Reporte asociado al mismo commit entregado; Quality Gate aprobado; 0 vulnerabilidades Blocker o Critical; cobertura >=80% por módulo y duplicación <5%.